정보보호컨설팅(Part Ⅱ)

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. 위험관리 기본
5. 시나리오 기반 위험분석
6. 컨설턴트 커리어 및 Q&A

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. 위험관리 기본
5. 시나리오 기반 위험분석
6. 컨설턴트 커리어 및 Q&A

1. 정보보호 관련 법·제도_정의

정보보호 관련 법규를 체계적으로 정리하면, 컨설팅·심사·사내 보안 정책 설계 시 기준을 명확히 이해할 수 있음

정보보호 관련 법규 개요

법령	제정 목적	적용 범위	주요 내용 / 특징
1. 개인정보 보호법	개인정보의 수집·이용·보관·파기 등 개인정보 보호	모든 기업 및 공공기관, 개인정보 처리자	- 개인정보 처리원칙(수집·이용 목적 명확화) - 개인정보 보호책임자 지정 - 안전성 확보 조치 의무 - 개인정보 유출 시 신고 의무 - 개인정보의 기술적·관리적 보호
2. 정보통신망 이용촉진 및 정보보호 등에 관한 법률 (정보통신망법)	정보통신망의 안정성·신뢰성 확보 및 개인정보 보호	인터넷 서비스 제공 사업자, ISP, 클라우드 서비스 등	- 해킹·악성코드 대응 의무 - 정보통신서비스 장애 보고 의무
3. 신용정보의 이용 및 보호에 관한 법률 (신용정보법)	신용정보 수집·이용·관리의 안전성 확보	금융기관, 신용평가사, 카드사 등	- 신용정보 수집·이용 제한 - 개인 신용정보 보호 조치 의무 - 정보 제공 시 동의 필수
4. 전자금융거래법	전자금융 거래의 안전성과 이용자 보호	전자금융업체, 금융기관	- 금융정보 보호, 인증 및 접근통제 강화 - 사고 발생 시 보고 의무 - 전자금융 사고 예방 및 대응 체계 구축
5. 중요정보통신기반시설 보호법 (정보통신기반보호법)	국가 핵심 기반시설 보호	금융, 통신, 전력, 교통 등 중요 정보통신기반시설	- 시설 지정 및 보호 의무 - 사고 대비 및 모의훈련 의무 - 정보보호 책임자 지정
6. 국가정보화 기본법 / 공공기관 정보보호 관련 법규	공공기관 정보시스템 안전성 확보	공공기관, 공기업	- 공공정보시스템 보호조치 기준 - 정보보호 관리체계(ISMS-P) 적용 - 정기적 보안점검 의무

1. 정보보호 관련 법·제도_정의

정보보호 관련 법규 개요

법령	제정 목적	적용 범위	주요 내용 / 특징
7. 산업별 가이드라인/표준 (예: 금융보안 가이드라인, 클라우드 보안 가이드라인)	산업별 특화 정보보호 체계 마련	금융, 의료, 클라우드, 통신 등	- ISO/IEC 27001, NIST, KISA 지침 등과 연계 - 기술·관리적 보호조치 상세 제시
8. ISO/IEC 27001 (국제표준)	정보보호 관리체계 구축·운영 표준화	전 세계 기업	- 정책·조직·물리·기술·운영 관리체계 요구사항 - 인증을 통해 국제적 신뢰 확보
9. ISMS / ISMS-P 인증 고시	국내 정보보호 관리체계 인증	국내 기업, 공공기관	- ISMS: 일반 정보보호 관리체계 인증 - ISMS-P: 개인정보 보호까지 포함 - 인증 범위·점검 항목 명시

핵심 포인트

- **법령별 적용 대상과 범위 명확화** → 기업/기관별 대응 체계 수립
- **개인정보보호 중심 법규와 산업별 특화 법규 구분** → 일반 정보보호 vs 금융/공공/클라우드
- **국내법 + 국제표준** 연계 가능 → ISMS/ISMS-P 인증, ISO 27001 등
- **기술적·관리적 보호조치 모두 포함** → 정책, 절차, 시스템, 물리적 통제까지 고려

1. 정보보호 관련 법·제도_법 체계

우리나라 법체계는 헌법을 최상위로, 법령 → 명령·규칙 → 지침·고시 등으로 하위 법규가 구성되는 계층 구조를 가지고 있음

법 체계

구분	명칭	설명	특징/예시
1. 헌법	대한민국 헌법	국가의 최고 규범, 모든 법의 근거	국민 기본권 보장, 국가 조직·권한 규정
2. 법률(Acts / Statutes)	국회에서 제정	국민의 권리·의무를 직접 규정	예: 형법, 민법, 정보통신망법, 개인정보 보호법
3. 대통령령 (Decree)	대통령이 제정	법률 시행을 위한 구체적 규정	예: 정보통신망법 시행령, 개인정보 보호법 시행령
4. 총리령 / 부령 (Ordinance)	부총리·부장관 등이 제정	법령·대통령령에 따른 세부 사항 규정	예: 행정안전부령, 과학기술정보통신부령 등
5. 규칙 / 고시 / 지침 (Rules, Notification, Guidelines)	행정기관에서 발행	세부적, 기술적·행정적 기준 제시	- 규칙: 내부 조직·운영 규정 - 고시: 국민·기업에게 공지 - 지침: 내부 운영 매뉴얼 수준
6. 조례 / 규칙 (Local Ordinances)	지방자치단체	지역적·현지적 법규 적용	시·도 조례, 구청 조례
7. 판례 / 행정해석	대법원, 행정기관	법률 해석 기준, 법적 권위	판례: 법원의 판단 기준 행정해석: 기관의 집행 기준

1. 정보보호 관련 법·제도_법 용어 정의

법을 이해할 때 자주 쓰이는 법 용어들을 정리

법 용어 정의

구분	용어	정의	쉽게 풀이
기본 법 체계	헌법	국가의 최고 규범. 국민 기본권, 국가조직 규정	"나라의 설계도"
	법률	국회에서 제정한 국민 권리·의무 규범	"국민이 반드시 지켜야 하는 큰 규칙"
	시행령	대통령이 제정, 법률의 구체적 집행 기준	"법을 실행하기 위한 설명서"
	시행규칙(부령)	부처 장관이 정하는 세부 규칙	"실무 매뉴얼"
입법 관련	조례	지방자치단체가 만든 지역 법규	"지역 주민을 위한 규칙"
	규칙	기관 내부 운영이나 행정 처리 기준	"회사 내부 규정 같은 것"
	고시	행정기관이 국민에게 알리는 행정 사항	"정부가 공식적으로 알림"
	지침	행정 내부 참고용 규정	"공무원 매뉴얼"
법 적용/해석	판례	법원(특히 대법원)이 내린 판결, 후속 사건 기준	"앞으로 같은 사건에 참고하는 기준"
	행정해석	행정기관이 법령 해석을 내린 것	"정부가 법을 이렇게 해석한다고 밝힘"
	유권해석	공식적·권위 있는 해석	"법적으로 인정받는 해석"
법적 효력 관련	강행규정	반드시 지켜야 하는 규정	"어겨도 무효"
	임의규정	당사자 합의에 따라 달리 정할 수 있는 규정	"합의가 우선"

1. 정보보호 관련 법·제도_법 용어 정의

법 용어 정의

구분	용어	정의	쉽게 풀이
소송 관련	피고	소송을 당한 사람/기관	"소송의 상대방"
	원고	소송을 제기한 사람	"소송을 건 사람"
	피의자	범죄 혐의가 있는 사람(수사 단계)	"경찰이 조사 중인 사람"
	피고인	형사재판에 넘겨진 사람	"법원에 기소된 사람"
법적 효력	효력 발생	법률이 실제 적용되기 시작	"시행일 이후부터 지켜야 함"
	공포	제정된 법률을 국민에게 알림	"이 법이 생겼다고 선포"
	시행	법률을 실제 적용 시작	"이제부터 법을 적용"

핵심 포인트

- **법률은 국회, 시행령은 대통령, 시행규칙은 부처 장관**이 만듭니다.
- **조례는 지방자치단체**, 즉 지역 차원의 규범입니다.
- **판례와 유권해석은 법 해석 기준**이 되어 실제 적용에 큰 영향을 줍니다.
- **강행규정 vs 임의규정** → 강행은 무조건 따라야 하고, 임의는 당사자 합의로 변경 가능.

1. 정보보호 관련 법·제도_개인정보보호법 주요 조항 정리

개인정보는 최소한만, 안전하게, 투명하게 처리하고 정보주체 권리를 보장해야 하며, 위반 시 강력한 제재가 따름

개인정보보호법 주요 조항 정리

구분	조항	주요 내용	쉽게 풀이	적용/사례
개인정보 정의	제2조	개인정보 = 살아있는 개인에 관한 정보로 특정인 식별 가능	이름, 주민번호, 영상, 음성 등 포함	CCTV 영상, IP 주소 등
개인정보 처리 원칙	제3조	수집 목적 명확화, 최소 수집, 안전한 처리, 정보주체 권리 보장	"필요한 만큼만, 안전하게, 투명하게"	회원가입 시 꼭 필요한 정보만 수집
개인정보 처리의 법적 근거	제15조	동의, 법률 근거, 계약 이행, 공공 필요 등 합법적 근거 있을 때만 처리 가능	"동의 없이는 마음대로 못 씀"	서비스 가입 동의서
민감정보·고유식별정보	제23조, 제24조	민감정보(건강, 정치 성향, 종교 등), 고유식별정보(주민번호 등)는 엄격한 보호	더 강한 보호 필요	병원 진료 기록, 주민번호
개인정보 수집·이용 동의	제22조	동의는 명확·자발적이어야 하고, 필요한 경우만 받아야 함	"숨겨진 동의 불가"	체크박스 분리, 필수·선택 구분
위탁 처리	제26조	개인정보를 제3자에게 위탁할 경우 계약 체결 및 관리·감독 의무	"맡기더라도 책임은 원래 기관에 있음"	클라우드 업체에 위탁
제3자 제공	제17조	제3자 제공 시 반드시 동의 필요 (예외적 법령 근거 존재 시 가능)	"내 정보, 남 주려면 허락받아야 함"	마케팅 제휴업체 제공
안전조치 의무	제29조	개인정보를 안전하게 관리하기 위한 기술적·관리적·물리적 조치 필요	"잠금장치 필수"	암호화, 접근통제, 보안 점검

1. 정보보호 관련 법·제도_정보통신망법 주요 조항 정리

정보통신망법은 개인정보보호법과 분리되어 현재는 “인터넷 서비스 안전·질서 유지법”으로, 불법정보 규제·스팸 방지·CISO 지정·ISMS 인증이 핵심

정보통신망법 주요 조항 정리

구분	조항	주요 내용	쉽게 풀이	적용/사례
목적	제1조	정보통신망 이용 촉진, 공정한 서비스 제공, 개인정보 보호, 건전한 이용환경 조성	인터넷 질서를 지키고 안전하게 쓰도록 함	온라인 서비스 전반
정의	제2조	정보통신망, 정보통신서비스 제공자, 이용자 등 용어 정의	어디까지 법이 적용되는지 경계 설정	통신사, 포털, 쇼핑몰
불법정보 유통 금지	제44조의7	음란물, 불법 도박, 명예훼손, 저작권 침해 정보 유통 금지	불법·유해 콘텐츠는 퍼뜨릴 수 없음	불법 도박 사이트 차단
게시물 임시조치	제44조의2	권리침해 주장 시 게시물 차단(임시조치) 제도	문제 글은 일단 내리고 확인	명예훼손 글 임시 삭제
본인확인조치	제44조의5	일정 규모(이용자 10만명↑)의 서비스는 본인확인 절차 마련	대형 플랫폼은 실명·휴대폰 인증 필요	대형 커뮤니티, 포털
정보보호 최고책임자(CISO) 지정	제45조의3	정보통신서비스 제공자는 CISO를 지정·신고해야 하며 겸직 제한	보안 책임자를 반드시 두어야 함	대기업, 대형 포털
정보보호 관리체계(ISMS) 인증	제47조	일정 규모 이상의 사업자는 ISMS 인증을 받아야 함	서비스 안정성과 보안을 객관적으로 검증	클라우드, 대형 쇼핑몰
광고성 정보 전송 규제(스팸 방지)	제50조	광고 전송 시 사전 동의 필요, 야간(21~08시) 추가 동의, 수신 거부 기능 필수	스팸 문자·메일을 막는 장치	마케팅 문자, 이메일
벌칙·과징금	제71조~제76조	위반 시 과태료·과징금·형사처벌 가능	규정 어기면 법적 제재	불법 스팸 발송 업체 적발

1. 정보보호 관련 법·제도_전자금융거래법 관련 주요 조항 정리

「전자금융거래법」 및 관련 감독규정(금융위원회·금감원 고시)에서 규정하는 것은 금융 서비스(인터넷뱅킹, 간편결제, 오픈뱅킹, 전자화폐 등)의 안전성을 보장하고, 이용자 보호를 위한 기술적·관리적·물리적 보안 의무를 명시

전자금융거래법 관련 주요 조항 정리

구분	주요 요구사항	세부 내용	적용/사례
1. 전자금융기반시설 보호	중요 전산망 분리	대외 접속망과 내부 업무망 분리 운영	인터넷뱅킹망 vs 내부업무망
	이중화 및 장애대응	시스템 이중화, DR센터(재해복구센터) 운영	금융사 DR센터 구축
2. 전자금융거래 안정성 확보	인증 강화	공인인증서 의무 폐지 후 다중인증(MFA) 적용	OTP, 생체인증, 간편인증
	전송 구간 암호화	금융정보 송수신 시 강력한 암호화	TLS/SSL 적용
	저장 데이터 암호화	계좌번호, 비밀번호 등 민감 정보 암호화 저장	DBMS 암호화, 키 관리
3. 접근통제 및 권한 관리	사용자 접근통제	비인가 접근 차단, 세션 타임아웃	로그인 10분 미사용 시 자동 종료
	최소권한 원칙	금융업무 권한 최소화, 변경 이력 관리	직원 업무 권한 분리
4. 이상거래 탐지(FDS)	금융보안 모니터링	비정상 거래 탐지·차단 시스템 운영	해외 접속 의심 거래 차단
	빅데이터·AI 분석	패턴 기반 위험 거래 자동 차단	동일 계좌 반복 송금 탐지

1. 정보보호 관련 법·제도_전자금융거래법 관련 주요 조항 정리

전자금융거래법 관련 주요 조항 정리

구분	주요 요구사항	세부 내용	적용/사례
5. 사고 대응 및 복구	침해사고 대응 체계	사고 대응 매뉴얼, 사고 신고 의무	해킹 시 즉시 금융당국 보고
	재해복구 훈련	정기적 복구 훈련 및 모의훈련 실시	연 1회 이상 DR 훈련
6. 전자금융업자 의무	보안성 심의	신규 전자금융서비스는 사전 보안성 심의 필수	신용카드 앱 신규 출시 전 심사
	ISMS 인증	전자금융업자는 ISMS 또는 동등 보안 인증 의무	간편결제·PG사
7. 이용자 보호	거래기록 보관	전자금융거래 내역 최소 5년 보관	카드결제 내역 보관
	책임 규정	해킹·사고 발생 시 금융사 책임 우선	고객 피해 발생 시 선보상

1. 정보보호 관련 법·제도_클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 주요사항

“클라우드법은 클라우드 산업 육성과 이용자 보호를 양축으로 하여, 제공자에게 보안·연속성 의무를 부과하고, 이용자에게 권리와 구제 수단을 보장하는 법

클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 주요 조항 정리

구분	주요 내용	설명
제정 배경	클라우드 서비스 확산, 데이터 산업 활성화	안정적 이용환경 확보 및 이용자 권익 보호 필요성 반영
목적(제1조)	산업 발전 + 이용자 보호	클라우드컴퓨팅 산업 발전 촉진과 안전한 이용 환경 조성
용어 정의(제2조)	클라우드컴퓨팅, 이용자, 제공자	서비스형 인프라(IaaS), 플랫폼(PaaS), 소프트웨어(SaaS) 등 정의
국가의 책무(제3조)	정책 추진	정부는 산업 진흥과 보안 강화를 위한 시책 마련
기본계획(제4조)	3년마다 수립	과기정통부 장관이 3년 단위 클라우드 기본계획 수립·시행
제공자 의무(제23조)	안정적 서비스 제공	서비스 연속성, 장애 시 복구 체계, 보안조치 시행
	개인정보·이용자 정보 보호	관련 법령(개인정보보호법, 정보통신망법 등)에 따른 안전조치
	계약서 교부	서비스 제공 시 계약서 필수 제공(서비스 내용·요금·책임 포함)
이용자 권리(제24조)	알 권리	서비스 내용, 장애·보안사고 발생 시 통지
	계약 해지권	제공자의 중대한 위반 시 계약 해지 가능
	피해 보상	서비스 장애·보안사고로 인한 손해배상 청구 가능

1. 정보보호 관련 법·제도_클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 주요사항

클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률 주요 조항 정리

구분	주요 내용	설명
보안 관련 조항	정보보호조치	물리적·관리적·기술적 보안조치 의무 부여
	침해사고 대응	사고 발생 시 이용자 통보, 관계기관 신고 의무
	중요정보 보호	공공·금융·의료 등 중요 데이터는 추가 보호조치 필요
공공부문 활용(제18조)	공공기관 클라우드 우선 활용	국가·공공기관은 클라우드 도입·이용 촉진 정책 반영
위반 시 제재	과징금·벌칙	의무 위반 시 과징금, 손해배상, 형사처벌 가능

1. 정보보호 관련 법·제도_법규와 컨설팅 연계

정보보호컨설팅은 정보통신기반보호법, 산업진흥법, 개인정보보호법, 금융 및 클라우드 보안 규정 등 다양한 법적 근거에 따라 제도화되고 전문화된 서비스로 정립되었음

정보보호컨설팅 관련 주요 법적근거

법령/제도	내용	적용/근거 조항
정보통신기반보호법	주요정보통신기반시설은 연 1회 이상 취약점 분석·평가 의무	제9조 (취약점 분석·평가)
정보보호산업의 진흥에 관한 법률	정보보호컨설팅은 정보보호 전문서비스업으로 정의됨	제23조 (정보보호 전문서비스 기업의 지정·관리)
정보통신망법 및 개인정보 보호법	ISMS 및 ISMS-P 인증 - 정보보호 및 개인정보보호 관리체계를 구축하고 적정성 평가	정보통신망법(제47조) 개인정보보호법(제32조의 2)
클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률	CSAP (클라우드 보안인증) - 공공기관 클라우드 이용 시 클라우드 보안 인증 필수	제23조의2 (클라우드컴퓨팅서비스의 보안인증)
전자금융거래법	전자금융 기반시설은 정기 보안 점검 및 위험 분석 필수	제21조3 (전자금융기반시설의 취약점 분석·평가)
개인정보보호법	개인정보 영향평가(PIA) 및 보호조치 의무화	제33조 (개인정보 영향평가)
정보보호산업의 진흥에 관한 법률	정보보호 투자, 인력, 인증, 활동 등 기업의 정보보호 현황 공개하는 자율·의무공시 제도	제13조 (정보보호 공시)
GDPR (EU 일반 개인정보보호법)	해외 진출 기업 대상 개인정보 처리 요건 및 평가 요구	Article 42 (GDPR 인증)
CBPR (APEC 프라이버시 보호 원칙)	개인정보보호 체계에 대한 글로벌(APEC) 인증제도 개인정보의 자유로운 국외 이전 처리	CBPR 인증기준(6개 분야, 총 50개 인증 기준)
ISO 27001, 27701, 27017(클라우드), 22301(BCP)	국제 표준 정보보호와 관련한 인증	ISO/IEC

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. 위험관리 기본
5. 시나리오 기반 위험분석
6. 컨설턴트 커리어 및 Q&A

2. ISMS 컨설팅 이해_ISMS 인증제도 개요

ISMS(Information Security Management System)는 조직이 수립한 정보보호 관리체계의 적정성, 효과성, 지속가능성을 공인된 심사기관이 객관적으로 심사하여 인증을 부여하는 제도

법적 근거 및 운영 체계

구분	내용
법적 근거	「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제47조
고시 기준	「정보보호 관리체계 인증 등에 관한 고시」 (과학기술정보통신부, 2023.12 개정)
주관 부처	과학기술정보통신부 (공식 주관)
인증 기관	한국인터넷진흥원(KISA)
심사 기관	KISA 또는 KISA가 지정한 민간 심사기관

인증 대상(의무기관 기준)

의무 인증 대상	예시
연 매출 1,500억 이상 사업자	대형 포털, 커머스 플랫폼
일일 이용자 100만 명 이상 웹 서비스 제공자	SNS, 스트리밍, 메신저
주요정보통신서비스 제공자	클라우드, IDC, CDN
공공기관 및 출연기관	지방자치단체, 공공서비스 운영기관

√ 의무 대상이 아니어도 자율 신청 가능: 수주, 입찰, 투자유치, 대외 신뢰도 제고 목적

2. ISMS 컨설팅 이해_관리체계 구축 필요성

관리체계 구축 필요성은 단순히 인증 취득(ISMS, ISMS-P, ISO27001 등)에 그치지 않고, 조직 전반의 정보보호 거버넌스와 보안 리스크 관리 차원에서 매우 중요

관리체계 구축 필요성

구분	필요성	상세 설명
법적·규제 준수	컴플라이언스 대응	개인정보보호법, 정보통신망법, 전자금융거래법 등 각종 보안 규제에서 **정보보호 관리체계 수립·운영**을 요구. 미비 시 행정처분·과징금·평판 리스크 발생
보안 리스크 관리	사이버 위협 대응	랜섬웨어, APT, 내부자 유출 등 다양한 침해사고에 체계적 대응 필요. 관리체계는 **위험분석 → 통제수립 → 대응 프로세스**로 리스크를 줄임
경영적 관점	비용 절감 & 효율성	보안사고 발생 시 복구·법적 대응 비용이 막대. 사전에 관리체계를 구축하면 **예방 비용 < 사고 대응 비용** 구조로 비용 최적화 가능
신뢰성 확보	대외 이미지·고객 신뢰	ISMS/ISMS-P, ISO27001 인증은 고객·파트너사·투자자에게 **보안 신뢰성을 입증**하는 역할. 특히 금융·공공 사업 수주에 필수 조건
지속 가능 경영(ESG)	ESG·CSR 연계	글로벌 ESG 평가 항목 중 **정보보호·개인정보보호**는 핵심 지표. 관리체계 구축은 기업의 **지속가능경영 및 사회적 책임** 수행의 근간
내부 보안 문화 정착	임직원 보안 인식 제고	정책·지침·절차 수립을 통해 **임직원의 보안 역할과 책임**을 명확히 하고, 교육·훈련으로 보안 문화 내재화
디지털 전환 대응	클라우드·AI 보안 체계 필요	클라우드, SaaS, AI 서비스 확산에 따라 새로운 보안 리스크 발생. 관리체계는 이러한 환경 변화에 **표준화된 대응 체계**를 제공

**관리체계 구축은 법적 요구사항 준수, 보안 리스크 예방, 신뢰성 확보,
ESG 경영 대응을 동시에 달성하기 위한 필수 전략**

2. ISMS 컨설팅 이해_관리체계 수립프로세스(1/2)

정보보호 관리체계는 단순히 정책을 만드는 것에 그치지 않고, 조직의 위험을 분석하고, 대응하고, 점검하고, 개선하는 전 과정을 체계적으로 운영하는 관리 사이클(PDCA)로 구성되어 있음

1단계: 관리체계 수립 및 운영 기반 마련

- **목적: 조직의 정보보호 활동이 임의적, 비정형적 방식이 아니라 제도적 기반을 갖추고 체계적으로 작동할 수 있도록 준비**
- **핵심 요소 및 활동**

구성 요소	상세 내용	요구되는 산출물
적용 범위 정의	인증 대상 자산, 부서, 시스템 명확화	적용범위 명세서, 구성도
정책 및 절차 수립	정보보호 정책, 세부지침, 절차서 작성	정책서, 지침서, 절차서
조직 구성	정보보호 책임자(CISO), 실무팀 구성	조직도, 책임·역할 정의서
법적 요구사항 파악	관련 법령, 내부 규정 검토 및 준수 계획	준수 법규 목록, 컴플라이언스 매핑

2단계: 보호대책 선정 및 구현

- **목적: 자산 식별 → 위험 분석 → 보호조치 수립이라는 위험 기반 접근 방식을 적용하여실질적 보호수단을 체계적으로**
- **핵심 요소 및 활동**

구성 요소	상세 내용	요구되는 산출물
자산 식별 및 분류	조직 내 보유 정보자산(서버, DB, 인력, 계약 등) 목록화 및 등급화	자산 목록표, 등급 분류표
위협 및 취약점 도출	위협 시나리오 분석, 취약점 점검 (자동/수기)	위협 도출표, 취약점 진단 결과
위험 분석 및 평가	자산가치 × 위협가능성 × 취약성 → 위험도 산정	위험분석 보고서
보호대책 선정	위험도 기준 보호조치 설정 (관리/기술/물리)	보호대책 적용계획서
기술 구현	암호화, 접근통제, 로그 수집, 백업 구축 등	구성도, 설정 캡처, 장비 스펙

2. ISMS/ISMS-P 컨설팅 이해_관리체계 수립프로세스(2/2)

3단계: 운영 및 점검

- **목적: 수립된 정책과 구현된 보호대책이 일상적으로 작동하는가? 를 검증, 단순 구성 여부가 아닌 운영 내역(기록, 교육, 사고대응) 확인**
- **핵심 요소 및 활동**

구성 요소	상세 내용	요구되는 산출물
정보보호 교육 실시	정기적 교육 (연 1회 이상), 역할 기반 교육	교육 계획, 이수 기록, 교육자료
이상징후 탐지	로그/이벤트 모니터링, SIEM 운영 여부	이상행위 탐지 기록, 대응 이력
보안점검 수행	자체 점검, 모의훈련, 계정/권한 감사	점검 체크리스트, 점검보고서
침해사고 대응	사고 탐지 → 조치 → 보고 프로세스 이행	사고이력표, 대응 보고서

4단계: 이행결과 개선

- **목적: 운영 결과를 분석하여 관리체계 고도화, 인증 유지, 재인증, 컴플라이언스 대응력 확보**
- **핵심 요소 및 활동**

구성 요소	상세 내용	요구되는 산출물
위험 재평가	자산 변화, 보안 사고 등 반영하여 재분석	재평가 보고서, 위험 수정 내역
감사결과 반영	내부·외부 감사, 심사 피드백 기반 개선계획 수립	감사 대응표, 개선 계획서
문서 갱신 관리	정책/절차/구성도 등 문서 최신화	변경이력표, 문서 버전관리대장
인증 유지 활동	사후심사 대응, 증적 정비)	사후심사 결과보고, 증적 개선내역

2. ISMS 컨설팅 이해_보호조치 3대 분야 개요(1/2)

보호조치란 조직의 정보자산을 위협으로부터 보호하기 위해 관리적, 기술적, 물리적 방법을 통해 실행하는 조직 차원의 보안 통제 수단임

**ISMS 기준에서는 3대 분야(관리적·기술적·물리적)로 구분하며,
조직 내 위험을 식별한 후 이를 감소시키기 위한 핵심적인 대응 수단**

관리적 보호조치

- **목적: 정보보호 체계를 전사적으로 운영하기 위한 조직 구성과 내부통제의 기반 마련, 사람, 정책, 절차 중심의 관리 역량을 평가**
- **대표 항목**

세부항목	설명	인증항목 수
정책수립	정보보호 정책서, 개인정보 처리 방침, 사용자 행동 규칙 등	약 20개 내외
정보보호 조직 구성	책임자 지정(CISO), 전담조직 존재 여부	
인식 제고 및 교육	연 1회 이상 교육 실시, 참여율 관리, 맞춤형 교육 적용	
자산 식별 및 분류	정보자산 현황 목록화, 등급 부여(중요도 기준)	
사고 대응 체계	침해사고 대응 절차 수립 및 사고 이력관리	

기술적 보호조치

- **목적: 정보 시스템과 네트워크에 존재하는 기술적 취약점에 대한 대응, 자동화/기계적 통제 수단을 통해 접근/사용/처리 등을 통제**
- **대표 항목**

세부항목	설명	인증항목 수
접근통제	관리자 계정 통제, 시스템 인증 절차, 계정 권한 최소화	약 30개 이상
암호화	저장 데이터, 전송 데이터 암호화, 암호 키관리	
악성코드 방지	백신 설치, 주기적 업데이트, 의심파일 차단	
로그 기록 및 검토	관리자 작업 로그 수집, 위변조 방지, 로그 보존기간	
네트워크 보안	방화벽, IPS/IDS 구성, 망분리 설계, VPN 설정	

2. ISMS 컨설팅 이해_보호조치 3대 분야 개요(2/2)

물리적 보호조치

- **목적: 물리적 환경(건물, 전산실, 장비)에 대한 위협으로부터 자산을 보호, 인프라 접근 제한, 출입기록, 감시 체계 중심**
- **대표 항목**

세부항목	설명	인증항목 수
출입통제	서버룸/통제구역 출입 권한자 한정, 출입기록 관리	약 10개 내외
전산설비 보호	서버/네트워크 장비 보호장치, UPS, 소방설비 등	
CCTV 운영	사각지대 없는 설치, 영상 저장, 열람 권한 관리	
물리적 이중화	주요 자산에 대한 이중 설비 및 백업 환경 구축	

2. ISMS 컨설팅 이해_수행 단계별 상세 활동

관리체계 수립의 핵심은 각 단계를 “문서화 및 증적화”하는 것이며, 다음은 ISMS 인증 준비 시 반드시 수행해야 하는 6단계 활동과 주요 산출물임

전체 수행 절차

- **계획 수립 → 자산 식별 → 위험 분석 → 보호대책 설정 → 문서화 → 운영 점검**

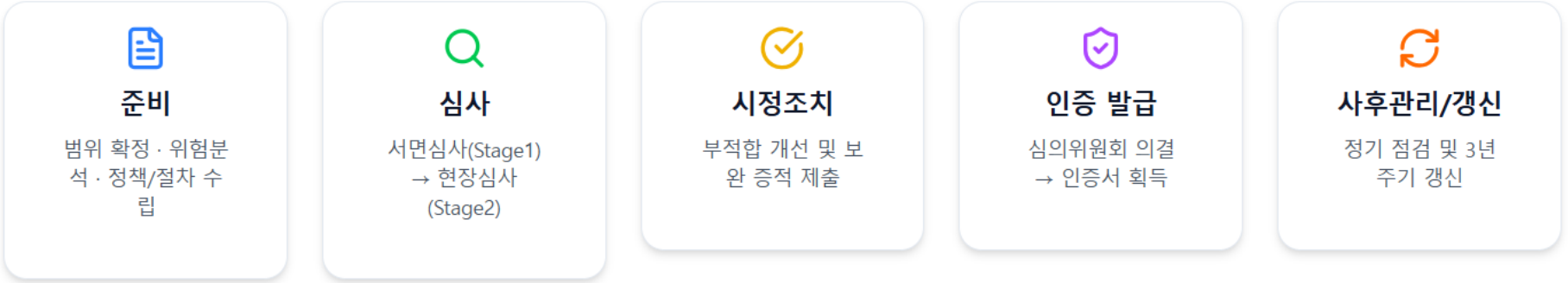
ISMS 수행 단계별 활동 정리표

단계	목적	주요 활동	대표 산출물	심사 중점
1. 계획 수립	관리체계 도입을 위한 정책 및 기반 마련	- 인증 범위 정의 - 정보보호 정책 수립 - 법령 파악 - 조직 구성(CISO)	- 정보보호 정책서 - 적용범위 문서 - 조직도 및 역할정의서	- 정책서 타당성 - 적용범위의 명확성 - 책임자 권한 부여 여부
2. 자산 식별 및 분류	보호 대상 자산의 식별 및 등급 분류	- 자산 목록 작성 - 등급 분류(CIA 기준) - 소유자 지정 - 시스템 구성도 작성	- 자산목록표 - 등급분류표 - 구성도	- 자산 누락 여부 - 등급 부여 기준의 일관성 - 소유자 명확성
3. 위험 분석 및 평가	위협 및 취약점 식별 → 위험도 평가	- 위협/취약점 도출 - 위험도 계산 - 위험처리 전략 도출	- 위험분석표 - 위험평가 보고서 - 위험처리계획서	- 분석기준 명확성 - 자산·위험 연계성 - 처리방안 타당성
4. 보호대책 설정 및 구현	위험 대응을 위한 통제수단 설계 및 실행	- 보호조치 적용(ISMS 80개 기준) - 기술/관리/물리적 조치 설계 - 보안 솔루션 도입	- 보호대책 계획서 - 보안설정 캡처 - 기술 구현 문서	- 보호조치 이행 여부 - 위험분석과의 연계성 - 설정 정합성
5. 문서화 및 증적 관리	모든 활동의 문서화 및 인증 대응 자료 준비	- 정책/절차/지침 문서화 - 운영 캡처/로그 수집 - 인터뷰 대응 정리	- 정책·지침서 - 로그/화면캡처 - 문서관리대장	- 문서-운영 간 일치성 - 증적의 실효성 및 위변조 방지 - 문서 최신성
6. 운영 점검 및 개선	관리체계가 실제 운영되고 개선되는지 검토	- 보안 교육 및 훈련 - 자체 점검 수행 - 사고 대응 이력 분석 - 개선 계획 수립	- 교육 실적표 - 점검 보고서 - 사고 대응 기록 - 개선보고서	- 교육 실적의 증빙 - 점검 내역 기록 - 개선 활동 추적 가능성

2. ISMS/ISMS-P 컨설팅 이해_ISMS 인증 절차 흐름도

ISMS 인증은 준비(범위·리스크·문서·증적) → 심사(Stage1/2) → 시정조치 → 발급 → 사후관리/갱신의 전주기 관리 프로세스

ISMS 인증절차 흐름도



ISMS 인증절차 상세

단계	주요활동	산출물/증적	책임(주도)	유의사항/베스트프랙티스
0. 사전진단/착수	요구사항 이해, 일정·역할 확정, 이해관계자 식별	착수보고서, R&R, 마일스톤	컨설팅사·고객사	경영진 스폰서 확보, 목표(KPI) 명확화
1. 범위·자산경계 확정	조직/사업/시스템 범위, 개인정보 처리 현황, 네트워크 경계 정의	범위정의서, 자산목록, 데이터흐름도	고객사(컨설팅 지원)	외부 위탁·SaaS 포함 여부, 경계 누락 방지
2. 현황진단 & Gap 분석	관리·기술·물리 통제 현 수준 점검, 법·기준 대비 격차 식별	Gap 분석 리포트, 개선목록	컨설팅사	규제·가이드 최신본 적용, 오탐/과탐 최소화
3. 위험분석 · 적용명세서 · 정책/절차 수립	자산·위협·취약점·영향 평가, 통제 적용 결정(적용명세서), 정책·지침·절차 문서화	위험분석 보고서, 적용명세서, 정책·절차 문서	컨설팅사·고객사	리스크 기준/평가등급 일관성, 개인정보 처리단계 반영

2. ISMS 컨설팅 이해_ISMS 인증 절차 흐름도

ISMS 인증절차 상세

단계	주요활동	산출물/증적	책임(주도)	유의사항/베스트프랙티스
4. 통제 구현 · 증적 확보	기술/관리/물리 통제 구현, 운영기록 수집(로그·점검표·교육기록 등)	운영증적(로그, 점검기록, 교육이수), 설정산출물	고객사(컨설팅 자문)	"종이 통제" 금지—운영사실 증적 필수
5. 내부심사/모의심사	문서·운영 적합성 사전 검토, 인터뷰 리허설	모의심사 결과서, 시정요구 목록	컨설팅사	인터뷰 대상별 Q&A 시나리오, 현장 동선 미리 점검
6. 시정조치 (1차)	부적합·관찰사항 개선, 재발방지 조치	시정조치 계획·결과서	고객사	원인-조치-증적의 연결고리 명확화
7. 인증 신청	신청서 제출, 수수료 납부, 일정 확정	신청서류 세트	고객사	범위/대상 최신화, 첨부 누락 확인
8. 서면심사 (Stage 1)	정책·절차·적용명세서 등 문서 적합성 검토	서면심사 지적사항	인증기관	문서 간 정합성(명칭·버전·책임자) 확보
9. 현장심사 (Stage 2)	인터뷰, 현장점검, 샘플링 증적 확인	부적합/관찰사항 보고	인증기관	샘플링 범위·증적 경로 사전 준비, 운영자 참석 확보
10. 시정조치 (2차)	현장심사 지적 보완, 재증적 제출	보완증적, 개선완료 보고	고객사	기한 내 제출, 조치 효과 증빙(로그·리포트)
11. 인증 심의·발급	심의위원회 의결, 인증서 발급	인증서, 심의결과 통보	인증기관	인증범위 표기 확인(조직·시스템 명칭)
12. 사후관리·유지	연간 점검/정기 심사 대응, 변경관리, 교육·점검 지속	사후관리 보고, 변경이력	고객사	조직/서비스 변화 발생 시 범위·통제 즉시 업데이트
13. 갱신심사(주기)	인증 주기 만료 전 재심사 준비(사전진단→심사 반복)	갱신 인증서	고객사·컨설팅사	주요 변화(클라우드 전환 등) 반영 재설계

2. ISMS 컨설팅 이해_ISMS 인증 심사 프로세스

ISMS 인증은 Stage 1(서면심사)와 Stage 2(현장심사) 두 단계 심사 프로세스로 진행되며, 각 단계별로 평가 기준·심사 활동·주요 증적이 다름

ISMS 인증 심사 프로세스

구분	단계	주요활동	심사범위/포인트	주요증적	결과/유의사항
1단계	서면심사 (Stage 1)	- 제출 문서 검토 - 관리체계 기본 충족 여부 확인 - 인증 범위 적정성 확인	- 정보보호 정책·지침 - 적용명세서의 타당성 - 위험분석 방법론·평가 적정성 - 문서 체계 정합성	- 정책/지침/절차 문서 - 위험분석 보고서 - 적용명세서 - 조직도·R&R	- 미비사항 보완 요청 가능 - Stage 2 진행 여부 결정 - 보완 기간(약 1~2주) 내 개선 필수
2단계	현장심사 (Stage 2)	- 운영 실태 인터뷰 - 현장 실사 및 샘플링 검증 - 증적 확인	- 관리적/기술적/물리적 보호대책 이행 확인 - 교육·훈련 실시 여부 - 로그 관리/보안 운영 기록 - 시설 보안·출입통제	- 시스템 로그/접근제어 증적 - 보안 점검표 - 교육/훈련 이수기록 - CCTV·출입통제 로그 - 장애/사고 대응 기록	- 부적합/관찰사항 도출 - 기한 내 시정조치 후 재검토 - 모든 주요 부적합 해소 시 인증 가능
3단계	심의위원회	- Stage 1·2 심사 결과 종합 검토 - 인증 적합성 의결	- 심사결과 종합 적합 여부	- 심사보고서·시정조치 결과	- 인증서 발급 여부 결정
4단계	사후관리	- 연간 점검(사후심사) - 인증 유효기간(3년) 관리	- 관리체계 운영 지속성 - 변경관리 반영 여부	- 연간 점검 보고서 - 개선 기록	- 미흡 시 보완 요구- 불이행 시 인증 취소 가능

심사에서 자주 지적되는 사항

- **문서-운영 불일치: 정책은 있으나 실제 운영 증적(로그, 점검표)이 없는 경우**
- **범위 정의 오류: 클라우드·외부 위탁 포함 누락**
- **증적 부실: 교육 기록, 로그, 점검 내역 미비**
- **리스크 평가 형식화: 현업 환경과 무관한 위험분석 결과**
- **시정조치 연결 약함: 원인–조치–증적 간 체계성 부족**

2. ISMS 컨설팅 이해_컨설팅 접근법(갭 분석 → 개선 → 대응)

갭분석 → 개선설계 → 실행·대응의 사이클을 통해 문제 발견→해결→검증→지속관리(사후관리)로 연결하는 통합 컨설팅 접근법

전체 접근법 (갭 분석 → 개선 → 대응)

단계	목표	주요 활동	산출물(예시)	책임/역할	활용도구, 메트릭
갭 분석 (Gap Analysis)	현재 운영 수준과 요구 기준(법·표준·정책) 간 격차 식별	범위 확정, 문서검토, 인터뷰, 시스템·로그 수집, 현장검증, 법·표준 매핑	Gap 분석 보고서, 우선순위 목록, 위험지도(Risk Heatmap)	컨설턴트 주도 / 고객현업 협조	Checklist, 스프레드시트, 자산목록, 취약점 스캔 결과
개선 설계 (Design & Prioritization)	실현 가능한 개선안 설계 및 실행계획 수립	개선옵션 설계(관리·기술·물리), 비용·ROI·우선순위 산정, 적용명세서 작성, 정책·절차 초안	개선 로드맵, 적용명세서, 정책/절차 문서, 예산·자원계획	컨설턴트+고객 의사결정자	GRC 툴, 워크숍, 비용 추정표
대응·구현 (Implementation & Response)	개선안 적용, 검증, 운영 반영	솔루션 설치/설정, 프로세스 정착, 교육·운영매뉴얼 배포, 내부심사·모의심사, 재검증	적용 증적(설정파일, 로그), 교육이수증, 재진단보고	고객 운영팀(컨설턴트 지원)	SIEM, 취약점 스캐너, 태킷/이슈관리 툴
성과 검증 & 사후관리 (Validation & Ongoing)	개선효과 확인·지속관리 체계화	성과측정, KPI 모니터링, 정기점검·갱신, 변경관리, 사고대응 연습	KPI 대시보드, 사후점검보고서, 변경이력	고객 운영/보안 담당 / 경영감독	Dashboard, SLA, 내부감사 체크리스트

2. ISMS 컨설팅 이해_ISMS 컨설팅 산출물 예시

ISMS 컨설팅의 핵심은 현재 운영 수준과 ISMS 요구 기준(법·표준·정책) 간의 격차를 분석하고, 이를 보완하는 산출물(Deliverables)을 만드는 것

ISMS 컨설팅 산출물 예시

현황분석
- 운영현황 보고서
- 규정/정책 목록

갭분석
- Gap Analysis Report
- 위험분석보고서

개선설계
- 개선과제 로드맵
- 관리·기술 대책 설계서

대응·구현
- 정책·절차 개정본
- 보안설정 점검결과

심사 준비
- 적용명세서(SoA)
- 운영 증적자료집
- 내부심사 보고서

사후관리
- 모의훈련 보고서
- 운영 점검 Checklist

구분	산출물 예시	주요 내용/설명	활용 목적
1. 현황 분석	① 현행 관리체계 운영현황 보고서	- 조직 정보보호 관리체계의 현재 운영 수준 정리 - 인력·조직·시스템·물리적 보안 등 현황 문서화	현황 기반으로 Gap 식별
	② 현행 규정/정책 목록	- 사내 정책·지침·내규 목록화 - 최신 개정일, 담당 부서 정리	인증 범위·갭 분석 기준 확보
2. 갭 분석	③ Gap Analysis Report	- ISMS 요구사항 80여개 통제항목 기준으로 현 운영과 차이 분석 - 미흡/부적합/양호 판정	개선과제 도출 근거
	④ Risk Assessment Report (위험분석보고서)	- 자산 식별, 위협·취약점 분석 - 위험도 평가 및 관리 방안 제시	위험기반 보호대책 수립
3. 개선 설계	⑤ 개선과제 로드맵	- 단기/중기/장기 개선 과제 분류 - 담당 부서·예산·우선순위 포함	실행계획 수립
	⑥ 관리적 보호대책 설계서	- 정책·절차·조직 개선안 - 교육/훈련/내부심사 프로세스 설계	관리적 통제 강화
	⑦ 기술적 보호대책 설계서	- 시스템 접근통제, 로그 관리, 암호화, 백업 등 보안 솔루션 적용 방안	기술적 통제 강화

2. ISMS 컨설팅 이해_ISMS 컨설팅 산출물 예시

ISMS 컨설팅 산출물은 크게 (1) 현황분석 → (2) 갭분석 → (3) 개선설계 → (4) 대응/구현 → (5) 심사 준비 → (6) 사후관리 단계별로 도출

ISMS 컨설팅 산출물 예시

구분	산출물 예시	주요 내용/설명	활용 목적
4. 대응·구현	⑧ 정책·지침·절차 개정본	- ISMS 기준 반영해 개정된 보안정책/절차 문서	인증 심사 증적
	⑨ 시스템 보안설정 점검 결과	- 서버·DB·네트워크 보안설정 결과 리포트 - 취약점 진단 보고서 포함	기술적 보완 증적
5. 심사 준비	⑩ 적용명세서 (SoA, Statement of Applicability)	- ISMS 요구사항별 적용여부 및 사유 정리	심사 핵심 문서
	⑪ 운영 증적 자료집	- 교육 이수 기록, 로그 보관 기록, 점검표, 변경관리 이력 등	Stage 2 현장심사 대응
	⑫ 내부심사 보고서	- 사전 내부심사 결과와 시정조치 내역	사전 보완 & 심사 준비
6. 사후관리	⑬ 모의훈련 보고서	- 침해사고 대응 모의훈련 결과 보고	지속적 개선 증적
	⑭ 운영 점검 Checklist	- 분기/연간 관리체계 점검 항목	사후심사·갱신 대비

2. ISMS 컨설팅 이해_인증 실패 사례 및 교훈

ISMS 인증은 서류 심사와 현장 심사를 모두 통과해야 하기 때문에, 일부 기업들은 기준 불충족이나 증적 미비로 실패하는 경우가 있음

ISMS 인증 실패 사례 및 교훈

구분	실패 사례	상세 내용	교훈
1. 문서·증적 미비	문서화는 했으나 실제 운영 없음	정책·지침·절차 문서는 제출했으나, 운영 증거(로그, 회의록, 기록 등)가 부족	"문서와 운영은 반드시 일치해야 함. 문서와 증적이 함께 준비되어야 함
2. 범위 설정 오류	인증 범위를 축소/모호하게 설정	실제 주요 정보자산(고객 DB, 주요 서버)이 인증 범위에서 제외되어 심사 거부	인증 범위는 **핵심 서비스·자산 포함**이 원칙
3. 위험분석 부실	자산·위협·취약점 식별 미흡	위험분석 산출물이 단순 형식만 갖추고 실제 위험 고려 부족	Risk Assessment는 **형식 아닌 실질적 리스크 기반**으로 작성
4. 보호대책 미 이행	취약점 개선 미완료	보안 진단에서 발견된 취약점(패치 미 적용, 접근통제 미흡 등)을 방치	**개선 조치 완료 후 증적**(스크린샷, 로그, 보고서 등)을 확보해야 함
5. 운영 미흡	정기 점검·교육 미수행	보안 교육 기록, 정기 점검 결과가 없거나 형식적 수행	**정기 운영 증적**(교육자료, 참석명단, 점검표)을 반드시 남길 것
6. 내부심사 부실	내부심사·경영검토 미 실시	내부심사를 생략하거나 '서명만 있는 형식적 보고서' 제출	내부심사·경영검토는 실제 회의 진행 + 시정조치 기록 필수
7. 관리적 측면 소홀	조직 내 역할 불명확	보안담당자 지정은 있으나 R&R(Role & Responsibility) 불분명	**조직 내 책임·권한 명확화** 필요
8. 사후관리 부재	인증 직전만 준비, 이후 방치	인증 취득 이후 운영 미흡, 사후심사에서 불합격	ISMS는 **일회성 아닌 상시 운영체계**라는 인식 필요

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. **개인정보보호 컨설팅**
4. 위험관리 기본
5. 시나리오 기반 위험분석
6. 컨설턴트 커리어 및 Q&A

3. 개인정보보호 컨설팅_개인정보보호 개념

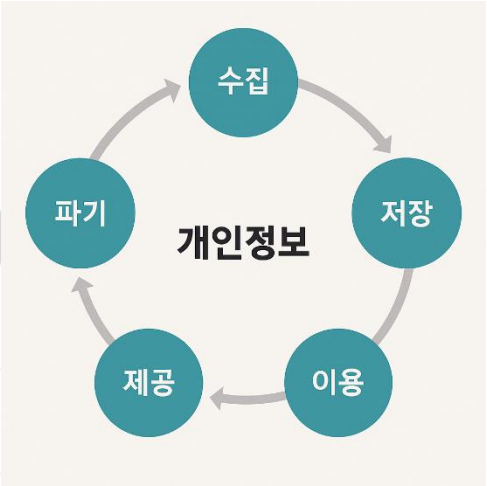
개인정보는 개인의 권리와 존엄을 담은 자산으로, 전 생명주기에서 보호가 필요하며, 개인정보보호는 법적 준수와 기술적/관리적 조치, 사회적 신뢰 확보를 모두 달성

개인정보보호 개념

구분	설명	구체적 예시	실패 시 위험
개인정보 정의	특정 개인을 직접 또는 간접적으로 식별할 수 있는 모든 정보	이름, 주민등록번호, IP주소, 위치정보, 쿠키	개인 추적, 신원 도용
보호 목적	개인 권리 보호, 법률 준수, 기업 신뢰성 확보	ISMS-P, GDPR, 개인정보보호법 준수	과징금, 소송, 고객 신뢰 하락
생명주기 단계	수집 → 저장 → 이용 → 제공 → 파기	최소한의 정보만 수집, 암호화된 저장, 접근권한 제한, 위탁 시 계약 관리, 완전 삭제	유출, 무단 활용, 불법 거래
보호조치	관리적, 기술적, 물리적 보안대책	내부 보안 교육, 암호화/접근통제, CCTV/출입통제	내부자 유출, 해킹, 물리적 침입
위협 요인	고의적 또는 실수로 인한 정보 유출	내부 직원의 무단 조회, 피싱 공격, 시스템 취약점	대량 유출, 평판 손실, 법적 제재
필요성	사고 예방, 고객 신뢰 유지, 경쟁력 확보	고객이 믿고 거래할 수 있는 브랜드	시장에서 도태, 투자자 불신

3. 개인정보보호 컨설팅_개인정보 생명주기(수집-파기)

개인정보는 수집부터 파기까지 전 생명주기에서 체계적으로 보호되어야 하며, 각 단계별 보호조치를 통해 법적 준수와 기업 신뢰를 동시에 달성



개인정보 생명주기(수집-파기)

단계	주요 활동	보호 원칙	보호 조치 예시
수집	필요한 최소한의 정보만 합법적으로 수집	목적 명확화, 최소수집	동의서, 수집 항목 제한
저장	안전하게 보관, 무단 접근 차단	안전성 확보	암호화, 접근권한 관리
이용	수집 목적에 맞게 활용	목적 외 사용 금지	권한별 접근통제, 로그 관리
제공(위탁)	제3자 제공·위탁 시 안전성 확보	계약 관리, 책임 명확화	위탁 계약, 제3자 관리 점검
파기	목적 달성 후 즉시 안전하게 파기	완전 파기, 복구 불가	완전 삭제, 물리적 파쇄
저장	안전하게 보관, 무단 접근 차단	안전성 확보	암호화, 접근권한 관리

3. 개인정보보호 컨설팅_개인정보 수집·이용 점검

개인정보 수집·이용은 '최소한의 정보'만 '명확한 목적' 하에 이뤄져야 하며, 동의 기반, 목적 제한, 불필요한 이용 금지가 수집·이용 점검의 핵심

개인정보 수집·이용

점검 항목	점검 내용	체크 포인트	위반 시 위험
수집 목적의 명확성	개인정보를 왜 수집하는지 구체적으로 명시	동의서에 '목적·항목·보유기간' 기재 여부	목적 외 사용 시 과징금, 법적 제재
최소 수집 원칙	서비스 제공에 꼭 필요한 정보만 수집	선택항목/필수항목 구분, 과도한 수집 금지	고객 불만, 불법 수집으로 제재
동의 절차 적정성	정보주체가 충분히 인지하고 동의했는가	동의서의 명확성, 사전·사후 동의 방식	무효 동의, 법적 분쟁
이용의 목적 제한	수집한 정보를 목적 외에 사용하지 않음	내부 시스템 접근권한 설정, 로그 기록 관리	무단 활용, 평판 손실
보유·이용 기간 준수	목적 달성 후 지체 없이 파기	보유기간 시스템 관리, 자동 파기 설정	장기 보관으로 인한 유출 위험



3. 개인정보보호 컨설팅_개인정보 보관·파기 점검

개인정보는 보관 기간을 철저히 관리하고, 목적 달성 후 반드시 안전하게 파기해야 하며, 불필요한 장기 보관은 유출 위험을 키우며, 완전 파기만이 법적·기술적 보호를 보장

개인정보 보관·파기

점검 항목	점검 내용	체크 포인트	위반 시 위험
보관 기간 준수	법령 및 동의 받은 기간 내에서만 보관	보유기간 자동 알림/만료 시스템	장기보관 → 대량 유출 시 책임
보관 안전성	저장 중에도 안전하게 보호	암호화, 접근통제, 로그관리	해킹, 내부자 오남용
파기 시기 적정성	목적 달성 후 지체 없이 파기	정기적 파기 스케줄, 자동 파기 설정	과징금, 법적 제재
파기 방법 적정성	복구 불가능한 방식으로 완전 파기	데이터 완전 삭제, 물리적 파쇄	복구 가능 시 재유출
위탁/제공 자료 회수	제3자에 제공된 자료도 동일 관리	위탁사 파기 확인서 확보	제3자 유출 시 공동 책임



3. 개인정보보호 컨설팅_위탁 관리

개인정보 위탁 시, 수탁사가 동일한 수준의 보호조치를 이행하도록 관리·감독해야 하며, 위탁 계약, 정기 점검, 파기 확인은 위탁 관리의 핵심 요소

개인정보 위탁 관리

점검 항목	점검 내용	체크 포인트	위반 시 위험
위탁 계약	개인정보 처리 위탁 시 계약 체결 필수	계약서에 목적·범위·보호조치 명시	법적 분쟁, 책임 불명확
수탁사 선정 기준	보안 역량·법규 준수 여부 평가	기술적/관리적 보호수준 검토	취약한 업체로 인한 사고 발생
정기 점검	수탁사 관리 상태 주기적 확인	현장 실사, 모의 점검, 보고서 제출	관리 부실 → 대량 유출
사후 파기 확인	위탁 업무 종료 시 파기 여부 확인	파기 확인서, 로그 증적 확보	개인정보 장기 보관 위험
책임 공유	사고 발생 시 공동 책임 발생	사고 대응 프로세스 협의	기업 신뢰·법적 책임 손실



3. 개인정보보호 컨설팅_개인정보보호 점검 체크리스트

개인정보보호 점검 체크리스트는 각 단계별 준수 여부를 확인하는 기본 도구이며, 체크리스트 기반 점검은 법적 요구 충족과 실무 관리수준 향상에 기여

개인정보보호 점검 체크리스트 예시

구분	점검 항목	점검 내용	준수 여부(✔/✖)
수집	최소 수집 원칙	서비스 제공에 필요한 최소 항목만 수집 여부	
	동의 절차	목적·항목·보관기간 명시 후 동의 받음 여부	
저장	안전한 보관	암호화, 접근통제 적용 여부	
이용	목적 외 사용 금지	동의받은 목적 이외 사용 금지 여부	
제공/위탁	계약 관리	위탁 계약서에 보호조치 명시 여부	
	수탁사 관리	정기 점검·파기 확인서 확보 여부	
파기	즉시 파기	보유기간 종료 후 지체 없이 파기 여부	
	완전 파기	완전 파기	

3. 개인정보보호 컨설팅_개인정보보호 결함 사례

개인정보보호 결함은 대부분 관리 부실·기술적 취약·절차 미 준수에서 발생하며, 결함 사례 학습은 동일 실수를 예방하고 개선 방안을 마련하는 데 핵심

개인정보보호 결함 사례

구분	결함 사례	발생 원인	영향	개선 방안
수집	불필요한 개인정보 항목 과도 수집	최소수집 원칙 미 준수	불법 수집, 고객 불만	필수/선택 항목 구분, 정기 검토
저장	주민등록번호 평문 저장	암호화 미적용	대량 유출 시 신원 도용	암호화 적용, 접근통제 강화
이용	내부 직원의 무단 열람	권한 관리 미흡	개인정보 오·남용, 법적 제재	접근권한 최소화, 로그 모니터링
제공/위탁	위탁 계약서에 보호조치 미기재	관리적 절차 누락	위탁사 사고 발생 시 공동 책임	계약서 표준화, 수탁사 정기 점검
파기	보유기간 만료 후 파기 미이행	파기 관리 시스템 부재	장기 보관 → 유출 위험 증가	자동 파기 시스템 구축, 파기 확인 절차

3. 개인정보보호 컨설팅_개선 권고안

개선 권고안은 결함 사례를 예방하고 개인정보보호 수준을 지속적으로 향상시키는 지침이며, 관리적·기술적·물리적 조치를 균형 있게 적용해야 효과적인 개선이 가능

개선 권고안

구분	개선 권고안	세부 내용	기대 효과
관리적 조치	개인정보 최소수집 원칙 강화	필수/선택 항목 명확화, 수집 목적 고지	불필요한 수집 방지, 법적 준수
	위탁사 관리 체계 정비	계약서 표준화, 정기 점검, 파기 확인서 확보	위탁사 보안수준 강화
기술적 조치	암호화 적용 확대	주민번호, 계좌번호 등 주요 개인정보 암호화	유출 시 피해 최소화
	접근통제 및 로그관리 강화	권한 최소화, 이상 접근 탐지, 로그 모니터링	내부자 오남용 방지
물리적 조치	보관 매체 관리	USB, 외장하드 사용 제한 및 반출입 통제	물리적 유출 차단
	문서 파기 절차 강화	파쇄기 사용, 파기 확인 기록 유지	복구 불가 파기 보장
운영적 조치	정기 교육 및 점검	임직원 대상 개인정보보호 교육, 내부 감사	보안 인식 제고, 재발 방지

3. 개인정보보호 컨설팅_보안사고 사례

보안사고 사례는 관리 부주의·기술 취약·내부 통제 미흡에서 반복적으로 발생하며, 사례 분석은 재발 방지 대책과 조직의 보안 수준 강화를 위한 교훈을 제공

보안사고 사례

구분	사고 사례	발생 원인	영향	개선 방안
내부자 유출	임직원이 고객 DB를 무단 다운로드 후 외부 반출	권한 관리 미흡, 로그 모니터링 부재	대량 개인정보 유출, 평판 손상	접근권한 최소화, 이상행위 탐지 강화
해킹 공격	웹사이트 SQL Injection 공격으로 개인정보 탈취	웹 취약점 미점검, 보안패치 미흡	고객 계정정보 대량 유출	정기적 취약점 점검, WAF 적용
피싱·스미싱	임직원이 악성메일 클릭 → 내부망 감염	보안 인식 부족, EDR 미적용	내부 시스템 마비, 업무 차질	보안 교육 강화, EDR/백신 도입
랜섬웨어	금융사 서버 암호화 → 서비스 중단	백업 미비, 보안 업데이트 미실시	업무 중단, 금전적 손실	주기적 백업, 침해대응 체계 구축
위탁사 사고	외주 업체 PC 해킹 → 고객정보 유출	위탁사 보안 수준 관리 부실	공동 법적 책임 발생	위탁사 정기 점검, 계약서 보안조치 명시

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. **위험관리 기본**
5. 시나리오 기반 위험분석
6. 컨설턴트 커리어 및 Q&A

4. 위험관리 기본_위험관리의 개요(1/3)

조직이 보유한 자산(asset)에 대해 잠재적 위협(threat)과 그에 악용될 수 있는 취약점(vulnerability)간의 관계를 분석하고, 그로 인한 정보 유출, 재정적 손실 등의 피해를 사전에 예측하고 적절한 대응 방안을 수립하는 과정

즉, 정보보호 위험관리는 "발생 가능한 보안 사고를 사전에 파악하고, 이를 최소화하기 위한 전략적 의사결정 체계"

위험관리의 주요 목적

목적	설명
정보자산의 보호	고객 정보, 인사 정보, 기업 비밀 등 핵심 자산의 안전 확보
위협 사전 대응	외부 공격, 내부 실수, 자연재해 등 다양한 위협 요소에 대한 대응
경영 리스크 통제	사고로 인한 금전적 손실, 명예 훼손, 법적 처벌 방지
정보보호 전략 기반 마련	ISMS, ISMS-P, ISO27001, PIA 등 인증 필수 절차
합리적 자원 배분	실제 위험이 높은 항목에 우선 대응함으로써 예산과 인력 최적화

위험관리의 핵심 구성 요소

구성요소	정의	예시
자산 (Asset)	보호 대상 정보/시스템/인프라/인력	고객 DB, 웹서버, 운영자 계정
위협 (Threat)	자산에 피해를 줄 수 있는 잠재 위험	해킹, 악성코드, 내부자 실수
취약점 (Vulnerability)	위협이 성공할 수 있는 약점	방화벽 미설정, 취약한 비밀번호

위험(Risk) = 자산(Asset) × 위협(Threat) × 취약점(Vulnerability)
→ “발생 가능성과 영향도”를 정량적 또는 정성적으로 평가

4. 위험관리 기본_위험관리의 개요(2/3)

위험관리 전체 프로세스 (ISO/IEC 27005 기반)

단계	설명	실무 예시
자산 식별	보호해야 할 정보/시스템/기기/조직 파악	"고객정보DB, ERP 서버, 사무용 PC" 등
위협 도출	자산별로 가해질 수 있는 위험 요소 파악	"외부 해킹, 악성코드 감염, 내부자 실수" 등
취약점 분석	위협이 자산에 영향을 줄 수 있는 약점 파악	"보안패치 미적용, 계정공유, 백업 미흡" 등
위험 평가	자산×위협×취약점 = 위험도 산정 → 정량·정성적 분류	상/중/하 또는 수치(예: 1~125점)
위험 처리	수용/회피/완화/전가 중 전략 선택 후 대응안 수립	백업 구축, 방화벽 설정, 교육 강화 등
위험 모니터링	대응 이후에도 주기적으로 위험 재평가	정기점검, 보안감사, 재진단 등

위험평가 방식 비교

방식	설명	예시
정성적 평가	위험도를 등급(상/중/하)으로 표현	XSS → "중간 위험"
정량적 평가	자산가치×위협가능성×취약성 → 점수화	자산=5, 위협=4, 취약성=4 → 총 80점
시각화 (Heat Map)	결과를 색상으로 매핑하여 한눈에 위험도 파악	빨강: 매우 위험 / 초록: 낮은 위험

4. 위험관리 기본_위험관리의 개요(3/3)

국제표준 및 법적 기준

기준	내용
ISO/IEC 27005	정보보호 전용 위험관리 프레임워크 정의
NIST SP 800-30	미국 국가표준 위험 평가 방법론
ISMS/ISMS-P 인증기준	"위험 기반 정보보호 조치" 필수 요구사항
개인정보 영향평가 지침(PIA)	위험 분석 및 완화 조치 기반 의무화

위험 처리 전략 (Risk Treatment)

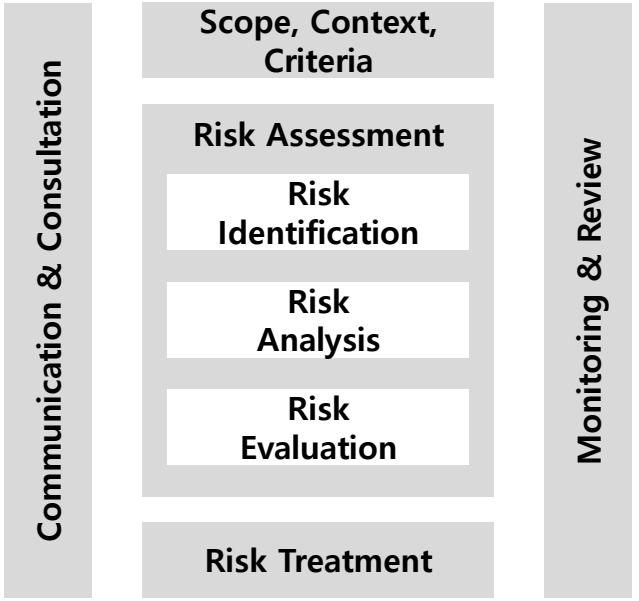
전략	설명	적용예시
수용 (Accept)	리스크를 인정하고 그대로 유지	영향이 작거나 비용이 클 때
회피 (Avoid)	자산 자체를 제거	오래된 서버 폐기
완화 (Mitigate)	보안 조치로 위협을 낮춤	암호화, 백업, ACL 설정 등
전가 (Transfer)	리스크를 외부로 이전	보험 가입, 외주 위탁 등

4. 위험관리 기본_위험관리 단계

위험관리는 식별·분석·평가·처리·모니터링의 순환 단계로 수행되며, 각 단계는 유기적으로 연결되어 지속적 개선과 리스크 최소화를 가능하게 함

위험관리 단계

단계	주요 활동	설명/예시
1. 위험 식별 (Identify)	자산·위협·취약점 파악	보호해야 할 정보자산, 발생 가능한 위협과 취약점 도출
2. 위험 분석 (Analyze)	가능성·영향 분석	위협 발생 가능성과 자산에 미치는 영향을 수치/등급화
3. 위험 평가 (Evaluate)	수용/대응 기준 결정	조직의 리스크 허용 기준(Risk Appetite)에 따라 우선순위 설정
4. 위험 처리 (Treat)	수용/회피/완화/전가 전략	기술적 조치(암호화, 방화벽), 관리적 조치(정책), 보험 등
5. 모니터링 및 검토 (Monitor & Review)	지속적 점검·개선	대응 조치의 효과성 검토, 환경 변화 반영
지원 활동	커뮤니케이션·기록 관리	이해관계자 협의, 문서화·보고 체계 운영



출처: ISO31000:2018 Risk Management Process

4. 위험관리 기본_자산식별 방법(1/2)

정보보호에서 자산 식별은 조직이 보호해야 할 정보자산을 체계적으로 파악하여 위협과 취약점을 연결하고, 위험 수준을 평가하기 위한 출발점

정보보호에서 자산 식별이란 다음과 같은 질문에 답하는 과정입니다:

"우리가 무엇을 보호해야 하는가?"
→ 정보보호의 출발점은 보호할 가치 있는 자산을 명확히 식별하는 것에서 시작합니다.

자산의 분류 기준 종류별(ISO/IEC 27005 기준)

자산 유형	세부 예시	설명
물리적 자산 (Physical)	서버, PC, 네트워크 장비, IoT 디바이스	실물 하드웨어 자산
소프트웨어 자산	OS, DBMS, 응용프로그램, API	설치 및 라이선스 관리 대상
정보 자산 (Data/Content)	개인정보, 소스코드, 이메일, 보고서	가장 보호 가치가 높은 유형
인적 자산 (People)	사용자, 관리자, 외주 인력	보안사고의 80%가 인적 실수/행위
네트워크 자산	VPN, 라우터, 방화벽, 스위치	정보 흐름과 경로 제어 장비
문서 자산	정책서, 매뉴얼, 계약서, 업무절차서	보안 정책 이행 근거 자료
서비스 자산	클라우드 서비스, 백업 서비스, 재해복구	업무 흐름과 기능 중심 자산

자산의 분류 기준 보안관점 속성

분류 기준	정의	적용 예시
중요도 (Criticality)	자산이 없어질 경우 업무에 미치는 영향	ERP 서버: 매우 중요
보안등급 (CIA 등급)	기밀성(C), 무결성(I), 가용성(A) 기준 분류	고객DB: 기밀성 상 / 무결성 중
운영환경	위치/망구조/접근권한 등 외부 노출 수준	내부망 vs DMZ 구간
접근권한 수준	관리자/운영자/일반사용자/외주 구분	운영자 계정: 고위험 자산

4. 위험관리 기본_자산식별 방법(2/2)

정보보호에서 자산 식별은 조직이 보호해야 할 정보자산을 체계적으로 파악하여 위협과 취약점을 연결하고, 위험 수준을 평가하기 위한 출발점

자산 식별 실무 절차(5단계)

단계	설명	실무 팁
1. 범위 설정	컨설팅 대상 부서/시스템 정의	본사/지점/클라우드 등 포함 여부 명확화
2. 정보 수집	자산 목록 확보 (Excel, CMDB, 관리자 회의)	시스템 관리자 + 부서 책임자 인터뷰 병행
3. 분류 작업	유형별/중요도별/등급별 라벨링	"고-중-저", "기밀성:상" 등 구분
4. 보안속성 부여	CIA 기준 가중치 또는 등급화	위험분석 연계 목적
5. 자산 등록 및 관리	목록화 → 위험 분석 연계	지속 갱신 체계 필요 (정기 점검 등 포함)

4. 위험관리 기본_위협목록 구성

위협(Threat)이란, 조직의 자산에 손실이나 피해를 줄 수 있는 잠재적 사건 또는 행위를 의미하며, 위협은 단독으로 위험(Risk)을 만들지 않지만, 취약점(Vulnerability)과 결합되면 위험(Risk)을 발생시킴

위협의 분류 체계 (ISO/IEC 27005 기반)_실무에서 활용하는 6가지 위협 범주

분류	세부 유형	설명	실무 예
자연적 위협	지진, 화재, 홍수, 폭풍, 낙뢰	외부 통제 불가한 자연환경 요인	데이터센터 정전으로 서비스 중단
기술적 위협	시스템 오류, 소프트웨어 버그, 네트워크 장애	IT 인프라 자체의 기술적 결함	패치 미적용 OS로 인한 침해
인적 위협	사용자 실수, 악의적 내부자, 교육 미비	사람에 의한 실수 또는 고의 행위	USB 분실, 내부자 계정 오남용
조직적/관리적 위협	정책 부재, 승인 없는 외주사용, 보안 미준수	절차와 제도의 결함	외부 협력사에 대한 보안 점검 누락
물리적 위협	출입통제 미흡, 장비 분실, 감시 실패	물리 자산에 대한 접근/제어 부재	CCTV 미작동, 서버실 무단출입
외부 사이버 위협	해킹, 랜섬웨어, DDoS, APT, 피싱	인터넷을 통한 의도적 공격	VPN 취약점 악용 공격, 관리자 사칭 이메일

자산별 위협 매핑 구성 방법

- **구성순서**
  - **식별된 자산 목록 확보**
  - **각 자산별 위협 유형별 가능 시나리오 작성**
  - **해당 위협의 영향(CIA)을 기준으로 위험도 예측**
  - **위협별 발생 가능성과 영향도를 문서화**

자산	위협	위협 유형	설명
고객정보DB	SQL Injection	외부 사이버 위협	웹 입력값 검증 미흡으로 인한 DB 노출
ERP서버	HDD 고장	기술적 위협	RAID 미구성으로 단일 디스크 장애 시 전체 마비
백업서버	정전	자연적 위협	UPS 부재로 정전 시 데이터 손실 가능
관리자 계정	권한 오용	내부자 위협	운영자에 의한 로그 삭제 및 무단 접속
네트워크 장비	패스워드 재사용	인적 위협	관리자 동일 암호 사용 → 일괄 해킹 우려

4. 위험관리 기본_취약점 도출 방식(1/2)

조직의 자산에 대한 보호 조치가 부족하거나 결함이 존재하여, 위협이 성공적으로 침투할 수 있는 약점을 의미, 위협이 "무기"라면, 취약점은 "열려 있는 문 " 이며, 단, 위협은 존재해도, 취약점이 없으면 실제 위험은 발생하지 않음

취약점 도출의 목적

- 조직의 정보자산이 어디에 얼마나 취약한지 파악
- 위협이 성공할 수 있는 경로를 차단하기 위함
- 위험도 평가 및 보호대책 수립의 기반이 됨
- 인증, 사고 대응, 보안 정책 설계의 핵심 입력자료

취약점 도출 방법

방법	설명	활용 시점
보안 진단 도구 활용	자동화 툴로 시스템, 웹, 네트워크의 알려진 취약점 스캔	기술진단, 정기점검
담당자 인터뷰	운영 실무자의 운용 현황 파악 (관리적·물리적 측면 포함)	ISMS/ISMS-P, 컨설팅 초기
문서·운영 로그 점검	정책서, 절차서, 감사기록, 접근로그 등 증적 분석	인증 대응, 사후 감사
보안사고 이력 분석	유사 조직/업종의 침해 사고 사례 분석	위험 시나리오 보강
코드 및 설정 검토	소스코드, 설정파일, 접근권한 등 직접 점검	개발보안, 시스템 점검
기준 기반 점검	OWASP, CVE, CWE, ISMS 등 국제표준 기반 항목 도출	기술진단, 보고서 구성

4. 위험관리 기본_취약점 도출 방식(2/2)

조직의 자산에 대한 보호 조치가 부족하거나 결함이 존재하여, 위협이 성공적으로 침투할 수 있는 약점을 의미, 위협이 "무기"라면, 취약점은 "열려 있는 문 " 이며, 단, 위협은 존재해도, 취약점이 없으면 실제 위험은 발생하지 않음

주요 참조 기준 정리

기준	설명	활용 분야
OWASP Top 10	웹 애플리케이션 10대 주요 취약점	웹 진단 보고서, 교육 자료
CVE (Common Vulnerabilities and Exposures)	취약점 DB 고유 식별번호 부여	시스템/애플리케이션 진단 시 참조
CWE (Common Weakness Enumeration)	취약점의 구조적 원인 유형화	보안 설계, 코딩 취약점 대응
CVSS (Common Vulnerability Scoring System)	취약점의 심각도를 0~10으로 평가	위험 평가 기준 및 리포트 작성
ISMS-P 기준	101개 인증항목 기반 점검	관리/기술/물리 보안 취약점 매핑

도출 항목 예시(취약점 → 자산 연계)

자산명	취약점명	도출 방식	영향도	대응방안
웹 포털	XSS (스크립트 삽입)	ZAP 도구 진단	기밀성 손상	입력값 필터링 적용
ERP 서버	계정 잠금 기능 미설정	인터뷰 + 설정 점검	무결성 훼손	로그인 정책 수정
DB 서버	미암호화된 저장	정책 미흡	기밀성 손상	저장시 암호화 적용
메일 서버	TLS 미사용	구성 설정 점검	기밀성 훼손	TLS 강제 적용
AD 서버	관리자 공유 계정 사용	인터뷰	무결성·추적성 손상	계정 분리 및 로그감사 활성화

4. 위험관리 기본_위험 분석 절차(1/2)

조직의 정보자산에 대해 예상 가능한 위협(Threat)이 특정 취약점(Vulnerability)을 통해 성공할 가능성과 그로 인해 발생할 수 있는 영향(Impact)을 계산하거나 등급화하는 절차

공식 : 위험(Risk) = 자산 가치 × 위협 발생 가능성 × 취약성 수준

이 분석을 통해 조직은 보호조치 우선순위를 정하고, 최소 비용으로 최대 효과의 대응전략을 수립할 수 있음

위험 분석의 목적

목적	설명
보호조치의 우선순위 수립	위험도가 높은 항목부터 먼저 대응
경영진 보고/의사결정 기반 제공	자산별 위험도 수치로 설명 가능
인증심사 대응	ISMS-P/PIA/CSAP 모두 위험분석 항목 존재
예산/자원 계획 수립	고위험 항목에 자원 집중 배분 가능

위험 분석 단계(ISO/IEC 27005 기반)

단계	주요 작업	결과 산출물
1. 자산 식별	보호 대상 자산 목록화	자산 목록표
2. 위협 식별	자산별 위협 시나리오 도출	위협 목록표
3. 취약점 도출	보호 결함/약점 식별	취약점 도출표
4. 위험 계산	위험 수치 또는 등급 평가	위험분석표
5. 위험 대응 결정	수용/회피/완화/전가 전략	보호조치 게획서

위험 평가 방식: 정량적 평가 vs 정성적 평가

구분	정량적 평가(Quantitative)	정성적 평가(Qualitative)
개념	수치 기반 계산 (곱셈 공식 등)	등급 구간별 분류 (높음/중간/낮음)
장점	비교 가능성 높음, 우선순위 도출 용이	적용 간단, 직관적 결과
단점	수치 기준 주관적/조작 가능성	사람마다 해석 다름
결과물	점수 기반 분석표 (예: 0~100점)	등급 기반 위험 매트릭스
활용	위험우선순위, 투자 우선순위 도출	인증심사, 교육, 현황정리 보고용
도구	CVSS, Excel 분석표	위험 매트릭스, 색상 구간 구분표

4. 위험관리 기본_위험 분석 절차(2/2)

조직의 정보자산에 대해 예상 가능한 위협(Threat)이 특정 취약점(Vulnerability)을 통해 성공할 가능성과 그로 인해 발생할 수 있는 영향(Impact)을 계산하거나 등급화하는 절차

위험 분석 공식 – 정량적 평가 방식

- **위험도(Risk Level) = 자산 가치 x 위협 가능성 x 취약성 수준**

요소	1점(낮음)	3점(중간)	5점(높음)
자산 가치	일반 문서	부서 시스템	ERP, 개인정보 DB
위협 발생 가능성	거의 없음	연 1회 발생	반복 발생, 실시간 위협
취약성 수준	조치 완료됨	일부 미흡	보안결함 방치, 미 조치

위험산정 점수화 테이블(정량 평가 예시)

자산명	자산가치	위협 가능성	취약성	위험점수	위험등급
고객 DB	5	4	4	80	매우 높음
ERP 서버	5	3	3	45	높음
웹 포털	4	2	3	24	보통
인트라넷	3	1	2	6	낮음

위험 점수 → 등급 기준

점수	위험등급	조치 권고
70~100	매우 높음	즉시 조치
40~69	높음	우선 조치 필요
10~39	보통	계획 수립 후 대응
1~9	낮음	모니터링 중심 대응

4. 위험관리 기본_위험 평가 사례

조직의 정보자산별로 특정 위협이 실제 발생할 가능성과 그로 인한 영향도(손실 규모)를 수치화 또는 등급화하여 보호조치 우선순위를 도출하는 활동

목적: 제한된 예산·시간 내에서 가장 중요한 보안위험부터 우선 대응

평가 기준: 자산 가치 × 위협 가능성 × 취약성 → 위험도 → 등급

위험 평가의 요소별 기준 (1~5점 예시)

평가 요소	기준 내용	예시 기준
자산 가치 (Asset Value)	해당 자산이 조직의 업무나 법규상 얼마나 중요한지	1 = 일반 웹페이지 3 = 업무 시스템 5 = 개인정보DB, ERP
위협 발생 가능성 (Threat Likelihood)	위협이 얼마나 자주 발생하는가	1 = 역사적 발생 없음 3 = 연 1회 발생 5 = 반복 발생, 공개취약점 존재
취약성 수준 (Vulnerability Severity)	위협이 성공할 확률이 얼마나 높은가	1 = 보안조치 완료 3 = 일부 조치 5 = 미조치 상태

위험 평가의 요소별 기준 (1~5점 예시)

자산명	자산가치	위협 가능성	취약성	위험점수(1~125)	위험등급
고객 DB	5	5	4	100	매우 높음
ERP 서버	5	3	3	45	높음
웹 포털	4	2	2	16	보통
인트라넷	2	1	1	2	낮음

4. 위험관리 기본_위험처리 전략(1/2)

위험처리(Risk Treatment) 는 조직의 자산에 대해 식별된 위험(Risk) 에 대해 "어떻게 대응할 것인가?"를 전략적으로 결정하는 절차

위험 처리 전략

전략	정의	적용 기준	예시	리스크 상태
수용 (Accept)	위험을 감수하고 그대로 유지	위험이 경미하거나 조치 비용이 과도할 경우	내부 공지 게시판 해킹 가능성 프린터 오작동으로 인한 단기 업무 지연	존재 → 허용
회피 (Avoid)	위험을 발생시키는 행위 자체를 제거	리스크가 과도하여 수용 불가한 경우	외부 결제 API 사용 중단 클라우드 도입 대신 온프레미스 유지	위험 원천 제거
전가 (Transfer)	위험을 외부 기관/제3자에게 전가	직접 대응이 어려운 영역, 보험/외주 등	클라우드 운영 외주, 사이버보험 사이버 보험 가입, 클라우드 서비스 SLA	위험 책임 분산
완화 (Mitigate)	보안통제/기술적 조치로 위험을 줄임	대부분의 보안 조치 적용 영역	암호화, 백신, 접근통제 적용 방화벽 설치, 취약점 패치, 모니터링 강화	위험 수준 감소



4. 위험관리 기본_위험처리 전략(2/2)

위험처리 전략 비교 요약표

구분	수용	회피	전가	완화
리스크 남김	남아 있음	제거됨	외부화	감소
비용 발생	거의 없음	간접비용 (기능 제거)	보험료/외주비	기술 투자 필요
책임 소재	내부	없음	외부에 일부 있음	내부
전략 목적	수용 가능한 위험 유지	위험 요소 제거	책임 전가 또는 분산	위험 수준을 낮춤
주 활용 사례	경미한 위험 / 비용 대비 효과 없음	개인정보 오남용 차단 / 규제 회피	침해사고 대응 / 법적 리스크 회피	암호화, 백신, 인증 등 일반적 대응

위험처리 전략 문서화 – 필수 작성 항목

전략	필요한 문서	핵심 구성요소
수용	위험수용 승인서	자산명, 위험 내용, 수용 사유, 책임자 승인
회피	대체 방안 설명서	중단 또는 변경할 사업/프로세스, 영향 평가
전가	계약서/보험증서	위험 책임 분담 조항, 보안 SLA
완화	보호대책 실행계획	조치 항목, 일정, 담당자, 예상 효과 등

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. 위험관리 기본
5. **시나리오 기반 위험분석**
6. 컨설턴트 커리어 및 Q&A

위험분석 실습

목차

1. 정보보호관련 법·제도
2. ISMS 컨설팅 이해
3. 개인정보보호 컨설팅
4. 위험관리 기본
5. 시나리오 기반 위험분석
6. **컨설턴트 커리어 및 Q&A**

6. 컨설턴트 커리어 및 Q&A_컨설턴트 성장 로드맵

컨설턴트 성장 로드맵은 주니어에서 시니어, 팀장, 그리고 전문 리더로 발전하는 경로를 체계화한 것이며, 기술 역량·관리 역량·리더십 역량을 균형 있게 강화하는 것이 핵심

컨설턴트 성장 로드맵

단계	역할/직무	핵심 역량	성과 지표 (KPI)	성장 포인트
주니어 (Rookie/Associate)	진단·분석 보조, 자료 작성	보안 기초 지식, 도구 활용 능력	진단 보고서 기여도, 문서 품질	**기초 지식·업무 습득**
시니어 (Consultant)	프로젝트 수행, 고객 대응	기술 심화, 커뮤니케이션	프로젝트 수행률, 고객 만족도	**실무 주도·신뢰 확보**
PL (Project Lead)	프로젝트 관리, 후배 멘토링	일정·품질 관리, 리스크 관리	프로젝트 납기 준수율, 팀 성과	**관리 역량 강화**
팀장 (Manager)	조직/팀 운영, 전략 제시	리더십, 사업개발	매출 목표 달성, 신규 서비스 기획	**리더십·사업 감각**
전문 리더 (Expert/Director)	대외 대표, Thought Leader	산업 전문성, 혁신 추진	업계 기여도, 컨설팅 서비스 차별화	**전문성·시장 영향력**

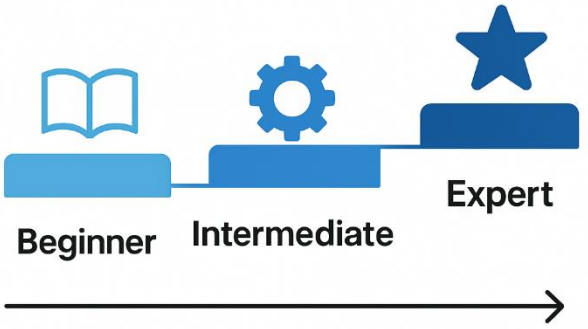


6. 컨설턴트 커리어 및 Q&A_초급 → 중급 → 전문가

컨설턴트 역량은 초급 → 중급 → 전문가 단계로 성장하며, 단계별 요구 역량과 역할이 다르며,
기술적 능력, 문제 해결력, 리더십을 균형 있게 발전시켜야 전문가로 성장할 수 있음

단계별 성장 로드맵

단계	역할/직무	핵심 역량	성과 지표	성장 포인트
초급 (Beginner/Junior)	단순 진단·보조, 자료 작성	보안 기초 지식, 도구 활용	보고서 기여도, 정확성	**기초 역량 습득**
중급 (Intermediate/Consultant)	프로젝트 수행, 고객 대응	기술 심화, 문제 해결력, 커뮤니케이션	프로젝트 수행률, 고객 만족도	**실무 주도·신뢰 확보**
전문가 (Expert/Senior Consultant)	프로젝트 총괄, 전략 제시, 후배 멘토링	리더십, 산업 전문성, 의사결정	신규 서비스 기획, 업계 영향력	**리더십·전문성 확립**



6. 컨설턴트 커리어 및 Q&A_필수 자격증 정리

보안 컨설턴트는 기술·관리·법규 영역의 전문성을 입증하는 자격증을 통해 경쟁력을 확보해야하며 국제 자격증과 국내 자격증을 균형 있게 취득하여 실무와 인증 대응에 활용해야 함



필수 자격증 정리

구분	자격증	기관/협회	특징 및 활용
국제 (기술/관리)	CISSP (Certified Information Systems Security Professional)	(ISC)²	정보보호 관리·기술 전반, 글로벌 표준
	CISA (Certified Information Systems Auditor)	ISACA	정보시스템 감사·통제·리스크 관리
	CISM (Certified Information Security Manager)	ISACA	정보보호 거버넌스·리스크 관리 특화
	CEH (Certified Ethical Hacker)	EC-Council	모의해킹·취약점 진단 전문
	ISO/IEC 27001 Lead Auditor	IRCA 등	ISMS/ISO 인증심사 수행 역량
국내 (기술/관리)	정보보호전문가 (CISSP 국내 대체)	KISA	국내 정보보호 관리·기술 전문
	ISMS-P 인증심사원	KISA	국내 ISMS-P 인증심사 참여 자격
	정보처리기사	한국산업인력공단	IT 전반 지식 기반
	개인정보관리사 (CPPG)	한국CPO포럼	개인정보보호 법제·실무 특화
보안 실무/특화	OSCP (Offensive Security Certified Professional)	Offensive Security	고급 모의해킹 실무
	CCSP (Certified Cloud Security Professional)	(ISC)²	클라우드 보안 특화
	AWS Security Specialty	AWS	클라우드 환경 보안 전문

Q&A